REPORTE DE VULNERABILIDADES

GPSMapApp — com.example.semana9

Documento redactado: reemplaza el PDF MobSF original porque ese artefacto exponía una clave de Google Maps. No contiene la clave ni credenciales.

Origen del análisis histórico: MobSF v4.6.1; archivo app-debug.apk; fecha visible 27-10-2026; Security Score 45/100 (riesgo medio, grado B). Este resultado corresponde al APK histórico, no al código recompilado después de las correcciones.

Hallazgos históricos relevantes

Hallazgo	Severidad / evidencia	Estado actual observado en código fuente
Certificado Android Debug	High; firma de depuración	Pendiente generar release firmado con keystore propio.
Debug Enabled (debuggable=true)	High en APK histórico	No se declara manualmente en el manifest actual; validar build release nuevo.
allowBackup=true	Warning en APK histórico	Manifest actual declara allowBackup=false y reglas de exclusión. Verificar APK nuevo.
ProfileInstallReceiver exportado	Warning AndroidX	Revisar manifest fusionado actual; no declarar corregido sin verificar.
Clave Maps hardcodeada	Se encontró una clave literal en el reporte original	Código actual la obtiene de local.properties/variable de entorno; clave antigua debe revocarse.
Sin Network Security Config	El escaneo histórico no detectó configuración	Se agregó configuración que prohíbe HTTP en claro; requiere recompilar y volver a escanear.
Permisos de ubicación	ACCESS_FINE_LOCATION y ACCESS_COARSE_LOCATION	Necesarios para ubicación del mapa; solicitar en tiempo de ejecución y justificar uso.

Controles confirmados en el código fuente revisado

• Consultas SQLite parametrizadas en DatabaseHelper.java.

• Contraseñas derivadas con PBKDF2-HMAC-SHA256, 100.000 iteraciones, salt aleatoria de 16 bytes y salida de 256 bits.

• Bloqueo progresivo de intentos mediante LoginAttemptGuard y LoginService; el control es local y depende del reloj del dispositivo.

• Sesión mínima en SharedPreferences privadas, con expiración de siete días. Las preferencias no están cifradas.

• allowBackup=false y reglas de exclusión de datos.

• Nueva configuración network_security_config.xml con cleartextTrafficPermitted=false y certificados del sistema; AndroidManifest declara usesCleartextTraffic=false.

• Clave Maps leída desde local.properties o MAPS_API_KEY; local.properties está excluido de Git.

Acciones obligatorias

• Revocar la clave Maps histórica desde Google Cloud Console y generar una nueva restringida al paquete com.example.semana9, SHA-1 y Maps SDK for Android.

• Compilar un APK nuevo y repetir análisis MobSF para verificar manifest, configuración de red, backup, componentes y secretos.

• Ejecutar ./gradlew testDebugUnitTest y ./gradlew connectedDebugAndroidTest; conservar la salida real.

• Generar una versión release firmada con keystore propio antes de distribución.

Limitación: durante la preparación de este paquete no se ejecutaron Gradle, un emulador ni un nuevo análisis MobSF. Por tanto, no se afirma que la compilación o las pruebas hayan pasado. El estado descrito como actual se basa en inspección del código fuente.